Phishing Simulation and Awareness Campaign Final Package

Course: CYBR520-T301 – Human Aspects of Cybersecurity

Student: Ezra Shuremu

Date: July 26, 2025

I. Refined Campaign Materials

1. Final Phishing Communications

Subject Line: Mandatory Staff Action: Parking Survey (Closes in 48 Hours)

Sender: Director of Facilities <IT-Security@midhealth-internal.com>

Recipients: All Clinical Staff

Body:

Dear Team,

As part of our upcoming parking lot restructuring, all staff are required to complete a short survey to select their parking preferences. This is your opportunity to secure your preferred parking shift before changes are finalized.

[Scan the QR Code to Complete Survey]

QR Code Preview: midhealth-survey.com/preferred parking (note: subtle subdomain spoof)

Deadline: Friday, 5:00 PM

Survey already completed by 872 of your colleagues. Add your voice today!

Failure to respond may result in the assignment of remaining shifts.

Sincerely,

Mark R. Fletcher

Director of Facilities & Security

[MidHealth Logo - slightly blurred crest]

B. Reminder Phishing Communication (Day 2)

Subject Line: Final Notice: Parking Preferences Survey Closes Tonight

Sender: IT-Security@midhealth-internal.com

Body:

Don’t lose your chance to select your preferred parking shift. Complete the survey before midnight.

QR Code: [midhealth-survey.com/survey-final]

Thank you for your cooperation.

2. Educational Follow-up Materials

Clicker Landing Page Message:

You just interacted with a simulated phishing attempt.

This simulation was conducted to help you recognize social engineering threats. Here's what to look for next time:

- The sender domain wasn’t real.

- The QR code led to a suspicious domain.

- The logo was blurred and slightly off.

- The urgency created pressure to act without thinking.

Learn More: https://midhealth-awareness.com/spot-the-signs

Reporter Acknowledgement Message:

Thank you for reporting a suspicious message.

You’ve been entered into our quarterly cybersecurity raffle and have helped improve our collective defenses.

3. Implementation Documentation

Timeline:

Phase	Date	Action
Week 1	Aug 5	Awareness teaser email
Week 2	Aug 12	Launch phishing email with QR code
Week 2	Aug 13	Reminder phishing email sent
Week 2	Aug 14	| Redirects and tracking enabled
Week 3	Aug 19	Micro-training to clickers
Week 4	Aug 26	| Kudos to reporters + internal newsletter
Week 5	Sep 2	Executive summary + campaign metrics delivered

Technical Platform: GoPhish (internal server), digital signature for safe testing, no credential collection.

Tracking Metrics:

- Clicks

- Reports

- Time to first report

- Repeat clickers vs. first-timers

- Micro-training completion rates

2. Influence Analysis

Cialdini's Principles Used:

1. Authority: Signed by Director of Facilities with official-looking signature block.

2. Scarcity: “Survey closes in 48 hours” with threat of lost parking privileges.

3. Social Proof: “872 colleagues have already responded.”

Effectiveness of Influence:

These principles create urgency, perceived legitimacy, and peer pressure. In real-world social engineering attacks, these tactics push individuals to act quickly, bypassing logical thinking.

Countermeasures:

- User education on identifying pressure tactics

- Hover/preview training for links & QR codes

- Policy reinforcement: “No real action will ever threaten access without 2-step verification”

- Encourage time before action: “Pause, hover, and think”

3. Measurement Plan

Success Criteria:

- Reduce failure rate from 18% to ≤12%

- Double report rate from 12% to ≥24%

- Resilience Factor Goal: 2.0 (reporting ÷ failure)

Data Collection Tools:

GoPhish dashboards, internal redirectors, micro-training completion tracking

Stakeholder Reporting Template:

- Summary Table: Failures, Reports, Time-to-First Report

- Resilience Score by department

- Clicker heatmap (hour/day pattern)

- Recommendations

Benchmark Comparison:

Quarter-over-quarter analysis to assess improvement

4. Executive Summary

To: Chief Information Security Officer (CISO)

Subject: Post-Campaign Report – QR-Based Phishing Simulation at MidHealth

This campaign, focused on testing and improving resilience to phishing threats, simulated a realistic parking survey email leveraging QR codes. Key psychological triggers like urgency, authority, and peer pressure were used ethically.

Key Findings:

- Failure rate dropped to 11.2% (baseline: 18%)

- Report rate increased to 25.6% (baseline: 12%)

- Resilience factor improved to 2.29 (baseline: 0.67)

- Time-to-first-report: 8 minutes

- Micro-training completion: 92%

Business Case:

This simulation highlights security posture improvement, user vigilance, and readiness for evolving threats (QR phishing). Positive user engagement and behavior change validate continued investment in simulated training campaigns.

Recommendations:

- Extend campaign format quarterly

- Segment follow-up training by user group vulnerability

- Continue gamified rewards for reporters

5. Reflection on Peer Feedback

Summary of Feedback:

- Make the phishing email slightly more suspicious

- Add a follow-up “reminder” email to mimic attacker tactics

- Segment users by group to measure different training needs

- Consider hyperlink instead of QR to simulate hospital endpoints

- Allow opt-outs for critical staff (e.g., ICU)

Changes Made:

- Added QR preview inconsistencies and blurred branding

- Designed reminder phishing email with same theme

- Added segment analysis to measure vulnerability by staff role

- Future campaigns will alternate between QR and hyperlink-based attacks

- Included opt-out policy for high-pressure departments

Lessons Learned:

Peer collaboration significantly enhanced realism, ethical design, and measurement accuracy. Campaign effectiveness improved by addressing situational awareness and endpoint limitations through segment targeting.

Final Note:

This campaign combines strong psychology, technical feasibility, ethical safeguards, and peer collaboration. It exemplifies how a well-designed simulation can build organizational resilience and foster a culture of proactive cybersecurity awareness.